



File No.: EXP202300329

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, A.A.A.) filed a complaint with the Spanish Agency for Data Protection on November 15, 2022. The complaint is directed against BANCO BILBAO VIZCAYA ARGENTARIA, S.A. with NIF A48265169 (hereinafter, BBVA). The reasons for the complaint are as follows:

A.A.A. states that an employee of BBVA, on October 30, 2022, provided, through an email message, banking information related to him to several people, without his consent. He adds that this employee was not authorized to access this information, as A.A.A. presented a power of attorney indicating that only his three attorneys could have access to his account. He further states that this employee extracted the aforementioned information from the banking entity, in physical form, and subsequently scanned the documents related to him to send them to third parties.

Along with the complaint, the following is submitted:

- A copy of an email dated October 30, 2022, at 8:31 AM, sent by "****EMAIL.1" to "****EMAIL.2", with copies to "****EMAIL.3; ****EMAIL.4; ****EMAIL.5; ****EMAIL.6; ****EMAIL.7; ****EMAIL.8; ****EMAIL.9".

This email had the subject "Re: (...)".

- A photograph of banking documentation, related to a bank statement dated March 3, 2020, from an account belonging to A.A.A. (Customer Account Code IBAN ES00 0000 0000 0000 0000). In its header, addressed to the complainant and to his postal address, it reads: "Dear customer, we are pleased to request details of the transactions you have requested."

- Two partial photographs of other documents in a different format, related to various concepts such as "(...)", showing date, amount, and some codes "(...)" followed by several numbers, also stating, at the far right of the document in relation to different concepts, the following: "(...)".

SECOND: B.B.B. (hereinafter, B.B.B.) filed a complaint with the Spanish Agency for Data Protection on November 17, 2022. The complaint is directed against BANCO BILBAO VIZCAYA ARGENTARIA, S.A. with NIF A48265169 (hereinafter, BBVA). The reasons for the complaint are as follows:

B.B.B. states that an "employee or former employee" of BBVA, on October 30, 2022, provided, through an email message, banking information related to B.B.B. to eight people, without his consent. He adds that this employee was not authorized to access this information and that he extracted it from the banking entity, in physical form, and subsequently scanned the documents related to him to send them to third parties.

Along with the complaint, he submits:

- A copy of an email dated October 30, 2022, at 8:31 AM, sent by "****EMAIL.1" to "****EMAIL.2", with copies to "****EMAIL.3; ****EMAIL.4; ****EMAIL.5; ****EMAIL.6; ****EMAIL.7; ****EMAIL.8; ****EMAIL.9".

This email had the subject "Re: (...)".

- Additionally, a copy of ten photographs containing stapled banking documentation is submitted, consisting of an amortization table for a loan, whose holder is B.B.B., with some documents showing handwritten notes indicating "Paid by me" and "The outstanding debts were paid by C.C.C. (...)".

THIRD: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGGD), the complaint filed by A.A.A. was forwarded to BBVA, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on January 16, 2023, as stated in the acknowledgment of receipt in the file.

On March 17, 2023, a written response from BBVA to the transfer of A.A.A.'s complaint was received, in which it states, among other things, the following:

- On March 16, 2023, BBVA's Customer Service communicated in writing to A.A.A. the decision made

regarding the complaint filed with this Agency, via an email sent to (...). Document No. 1 is submitted, addressed to A.A.A. with, among other content, the following:

“(…) Likewise, we inform you that the email address you provided and according to which you state that BBVA is responsible for the unauthorized transfer of your personal data, does not correspond to any domain of the BBVA Group. Since the sender is a personal address, not linked to the BBVA Group, the Entity cannot determine the identity of the sender and the authenticity of the email. Considering that the bank statement allegedly attached to the email is dated 03/03/2020, and that this email was sent on 30/10/2022, it does not...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/28

evidences a causal link between access and the subsequent sending of the email, taking into account, as previously indicated, that this is done from an email address unrelated to the BBVA Group. (...)”

- As a result of the analysis, it has been detected that on March 3, 2020 (date of the account statement), a query of movements of the IBAN account ES0000000000000000000000 was made from the office (...) located at ***ADDRESS.1, which does not correspond to the managing office of the account. The user listed in the transaction record, who therefore accessed the balance and movements of the account, is no longer associated with BBVA due to their enrollment in the ERE (Employment Regulation File) effective from 01/08/2021. The termination of the employment relationship has prevented the Entity from knowing the worker's version of the events.

- The email provided with the claim from A.A.A. and used to substantiate the non-consensual transfer of their personal data is a forwarding of an email to another user ((...)), and in this process, the content of the email may not match the original text for various reasons.

- The email that, according to A.A.A., is attached with the statement of their bank account dated 03/03/2020, is sent from the address (...) which does not belong to the BBVA Group domain (@bbva.com). Since the sending email address is a personal address not linked to BBVA, it cannot determine the identity of the sender and the authenticity of the email.

Considering the date of the bank statement 03/03/2020 and the date of the email sent 30/10/2022, BBVA believes there is no apparent causal link between said access and the sending of the email in which the bank statement is supposedly attached, as it occurs more than two years later, and the sending address is unrelated to the BBVA Group.

- A copy of the following documentation is provided, relating to the security and confidentiality of personal data:

☐ As Document No. 2: “Data Protection and Customer Experience Protocol” created in collaboration with the Data Protection Office (DPO) and containing recommendations on how to handle customers' personal data with security and confidentiality. The protocol is available on the Entity's internal intranet, making it accessible to employees.

In this document, among others, the following content is observed:

☐ “(…)”.

☐ “(…)”.

☐ “(…)”

☐ As Document No. 3: Information to employees via a news bulletin called “Today” provided on Monday, March 12, 2018, which includes a link to the protocol referred to in the previous section. In this document, among others, the following content is observed:

“(…)”.

☐ As Document No. 4: “Code of Conduct of the BBVA Group” which includes the obligation of employees to maintain and safeguard the confidentiality of the data they handle. Furthermore, they are obliged not to disseminate, transmit, or disclose to third parties any information related to or data they have access to as a result of their activity, nor to use such information for their own benefit. This obligation will persist even after the contractual relationship has ended.

In this document, among others, the following content is observed:

- ☐ “(...).”
- ☐ “(...).”
- ☐ “(...).”
- ☐ “(...).”
- ☐ “(...).”

Employees who were enrolled in the ERE formalized a “Termination Letter” with the Entity, which included the obligation of confidentiality and professional secrecy, a copy of which is attached.

It is also noted that: “The aforementioned internal regulation on “Protection of Personal Data” applies to any processing of personal data carried out, regardless of the group to which the data belongs: customers, non-customers, employees, shareholders, representatives, etc., applies to all units that make up the geography of Spain subject to compliance with the regulatory requirements of the country, is available to employees, and its content is regularly reminded through information campaigns.

In the aforementioned regulation, the following provision is warned, which relates to the object of this claim: (...)”

FOURTH: In accordance with Article 65.4 of the LOPDGDD, the claim submitted by B.B.B. was forwarded to BBVA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the established rules in the LPACAP, was received on 01/16/2023 as evidenced by the acknowledgment of receipt in the file.

On March 17, 2023, a written response from BBVA to the transfer of the claim submitted by B.B.B. was received, in which it states, among other things, the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/28

- The email provided with the claim from B.B.B. and used to substantiate the unauthorized transfer of their personal data is a forwarding of an email to another user ((...)), and in this process, the content of the email may not match the original text for various reasons.

- The email that, according to B.B.B., has attached the photographs submitted, is sent from the address (...) which does not belong to the BBVA Group domain (@bbva.com). It results that the sender's email address is a personal address not linked to BBVA, making it impossible to determine the identity of the sender and the authenticity of the email.

- Regarding the submitted photographs: (i) the first three images appear to be related to the mechanical validation of account deposits; if so, the person making the deposit receives a copy of the deposit receipt; (ii) the third image is illegible and seems to be a screenshot from the BBVA application; (iv) the fifth, sixth, and seventh images appear to correspond to an amortization table for a loan (installments from 2003 to 2013); there is no causal link between these images and the alleged unauthorized data transfer by BBVA as claimed by the complainant. The images that B.B.B. claims to accompany are included in an email whose sender cannot be identified, as it is a personal address and the domain has no relation to BBVA. It is not evident that access to the documentation apparently from the years 2008 and 2013 was provided by BBVA to a third party other than the holder. Any document that corresponds, for example, as in this case, to a loan amortization table, in the hands of a third party different from the holder, does not imply that there has been a violation of the client's data protection by the Entity, since access to the document once it is delivered to the client during the formalization of the operation is beyond the Bank's control.

- A copy of the following documentation is provided, relating to the security and confidentiality of personal data:

☐ As Document No. 2: “Data Protection Protocol and Customer Experience,” which is the same document submitted by BBVA in its response letter dated March 17, 2023, regarding the transfer of the claim from A.A.A., noted in the third fact.

☐ As Document No. 3: Information to employees through a newsletter called “Hoy” provided on

Monday, March 12, 2018, which is the same document submitted by BBVA in its response letter dated March 17, 2023, regarding the transfer of the claim from A.A.A., noted in the third fact.

□ As Document No. 4: "Code of Conduct of the BBVA Group," which is the same document submitted by BBVA in its response letter dated March 17, 2023, regarding the transfer of the claim from A.A.A., noted in the third fact.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/28

- The aforementioned internal regulation on "Personal Data Protection" applies to any processing of personal data carried out, regardless of the group to which the data belongs: clients, non-clients, employees, shareholders, representatives, etc. It applies to all units that make up the geography of Spain subject to compliance with the regulatory requirements of the country, is available to employees, and its content is regularly reminded through information campaigns.

They state that the aforementioned regulation includes the following warning, which is related to the subject of this complaint: "(...)."

FIFTH: On February 15, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by A.A.A. was admitted for processing.

SIXTH: On February 17, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by B.B.B. was admitted for processing.

SEVENTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

On June 21 and August 21, 2023, two documents were received by this Agency in response to requests for information regarding the complaint submitted by B.B.B., in which BBVA states the following:

1. The data of B.B.B. is blocked under LOPD as a result of the cancellation of all products at BBVA in December 2020, and there have been no active contracts since that date. An image of a search by "NIF PERSONA FISICA" with Document "****NIF.1" is attached, showing "No data available for the query."
2. The first three images correspond to proof of cash deposits into the account, with the date of the proofs appearing to be from the year 2002 or 2003. To make a deposit into an account by someone who is not listed as an intervenor of the same, the account number where the deposit is requested is required. The general retention period for documents is ten years from the termination of the business relationship or the execution of the operation caused (Article 29.1 of the regulation of Law 10/2010 on the Prevention of Money Laundering).
3. Regarding the amortization schedule of a loan, it is an integral part of the contract or policy formalized between the holder and the Entity. According to the capture of the software application, the loans were canceled in 2005, 2009, and 2013.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/28

4. There are no accesses in the year 2022. From 03/2020 to 03/12/2020, there are 137 records; the analysis of the accesses has not resulted in any suspicious activity or activity lacking motivation other than usual commercial actions. On August 22, 2023, a document was received by this Agency in response to a request for information regarding the claim submitted by

A.A.A.

in which BBVA states the following:

1. Clients must identify themselves with their DNI and/or original and valid identification document, even if the office has scanned the document provided at the account opening, regardless of the amount to be withdrawn. They provide a copy of the internal regulation "Regulation for the admission, identification, and knowledge of clients."
2. The user who made the inquiry on 03/03/2020 (date of the account statement) from the office (...), regarding the movements of the IBAN account ES0000000000000000000000, according to BBVA's records, corresponds to Mr. C.C.C. (hereinafter, C.C.C.), an employee of the entity from 03/16/1992 to 08/01/2021, the effective date of voluntary resignation incentivized due to his assignment to the ERE (Employment Regulation File).
3. They add that BBVA has the Group BBVA Code of Conduct, the internal data protection regulations (GDPR), and the procedure for verifying and accrediting the identity of clients at the counter available to its employees on the internal intranet, and periodically sends informative bulletins via email with the most relevant information contained in the aforementioned documents. The Group BBVA Code of Conduct is part of one of the mandatory trainings that employees of the entity undergo.
4. Regarding the training received by C.C.C., Document No. 3 is attached, which includes the training recorded since 2018, and where among other courses the following are listed:

(...)

EIGHTH: According to the "Annual Report 2022," published at https://accionistaseinversores.bbva.com/wp-content/uploads/2023/03/Informe-Anual-BBVA_2022_esp.pdf, in the year 2022, BBVA's profit amounted to 6.420 billion euros, and it had more than 89 million clients, as stated in the diligence included in the file dated February 9, 2024.

NINTH: On February 15, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against BBVA, in order to impose an administrative fine of 70,000.00 euros for the alleged violation of Article 32 of the GDPR, classified under Article 83.4 of that regulation, in which it was indicated that BBVA had a period of ten days to submit allegations. This initiation agreement, which was notified to BBVA in accordance with the rules established in the LPACAP, was recorded on February 16, 2024, as stated in the acknowledgment of receipt in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/28

On March 8, 2024, this Agency received, in due time and form, a document from BBVA in which it presents allegations against the initiation agreement.

TENTH: On August 8, 2024, BBVA proceeded to pay the fine in the amount of 56,000.00 euros, utilizing one of the two reductions provided for in the aforementioned initiation agreement, and has submitted a document with the following content:

“(...)

X. That, as a consequence of the aforementioned payment, my represented party waives the exercise before that AEPD of any action or administrative appeal against the sanction, as prescribed by Article 85.3 of the LPACAP, therefore stating that it will not file an optional appeal for reconsideration against the resolution that may ultimately be issued.

XI. That, however, and as indicated in the previous recitals, the aforementioned payment is made in exercise of the power established in Article 85.3 and does not imply in any case agreement with the content of the Initiation Agreement nor with that of the resolution that may be issued, if it corresponds, in whole or in part, with the content of said Agreement. Likewise, the making of said payment shall in no case be interpreted as an acknowledgment by BBVA of responsibility for the commission of the alleged sanctions that may be imposed on it in the aforementioned resolution. (...)”

ELEVENTH: The payment made entails the waiver of any action or administrative appeal against the sanction, in relation to the facts referred to in the Initiation Agreement.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following

facts proven in the present procedure,

PROVEN FACTS

FIRST: On October 30, 2022, C.C.C. sent an email to "****EMAIL.2," with a copy to "****EMAIL.3; ****EMAIL.4; ****EMAIL.5; ****EMAIL.6; ****EMAIL.7; ****EMAIL.8; ****EMAIL.9."

This email had the subject "Re: (...)" and was accompanied by an image of a banking document, relating to a bank statement dated March 3, 2020, from an account belonging to A.A.A. (Client Account Code IBAN ES00 0000 0000 0000 0000). In its header, addressed to A.A.A. and to their postal address, it reads: "Dear client, we are pleased to request details of the movements you have requested."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/28

The email also included two partial images of other documents in a different format, related to various concepts such as "...", showing date, amount, and some codes "..." followed by several numbers, also stating, on the far right of the document in relation to different concepts, the following: "...".

SECOND: On October 30, 2022, ****EMAIL.1 sent an email to "****EMAIL.2", with copies to "****EMAIL.3; ****EMAIL.4; ****EMAIL.5; ****EMAIL.6; ****EMAIL.7; ****EMAIL.8; ****EMAIL.9". This email had the subject "Re: (...)" and included ten images with attached bank documentation, consisting of an amortization table for a loan, whose holder is B.B.B., with some documents containing handwritten notes indicating "Paid by me" and "The outstanding debts were paid by C.C.C. (...)"

THIRD: The email address used to send such emails does not correspond to any domain of the BBVA Group; it is a personal address.

FOURTH: On March 3, 2020 (date of the account statement), a query regarding the movements of account IBAN ES000000000000000000000000 was made from the office (...) located at ****ADDRESS.1, which does not correspond to the managing office of the account. The user listed in the transaction record, and who therefore accessed the balance and movements of the account, corresponds to C.C.C., an employee of BBVA from 03/16/1992 to 08/01/2021, the effective date of voluntary resignation incentivized due to his affiliation with the ERE (Employment Regulation File).

FIFTH: BBVA has a document without date, signature, or indication of the version to which it corresponds, titled "Data Protection Protocol Data Protection Office (DPO)". In this document, among other content, the following is observed:

- "(...)"
- "(...)"
- "(...)"

SIXTH: BBVA provided information to its employees on March 12, 2018, through a news bulletin called "Hoy" that includes a link to the document "Data Protection Protocol and Customer Experience". In this bulletin, among other content, the following is observed:

"(...)"

SEVENTH: BBVA has a document titled "BBVA Group Code of Conduct", without date, signature, or indication of version, in which the following content is observed, among others:

- (...)
- (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/28

- (...)
- (...)
- (...)

- (...)

EIGHTH: BBVA has a consultation channel for any possible doubts that may arise regarding the application of the "BBVA Group Code of Conduct", with the following content:

"(...)."

NINTH: BBVA has a reporting channel available to its employees to communicate behaviors that constitute a breach of the Code of Conduct, in which it can be seen:

"(...)."

TENTH: BBVA employees who joined the ERE formalized a "Termination Letter" with the Entity, which included the obligation of confidentiality and professional secrecy.

ELEVENTH: BBVA has a document titled "General Privacy and Data Protection Policy" established by the Board of Directors of BBVA, unsigned, first version of the document, dated September 28, 2022, with the following content, among others:

"(...)."

TWELFTH: BBVA has a document titled "Corporate Standard for the Protection of Personal Data", unsigned, first version of the document, dated May 19, 2023, with (among others) the following content:

"(...)."

THIRTEENTH: BBVA has a document titled "Standard for the Protection of Personal Data", unsigned, version 8, dated April 1, 2022, in which the following content can be seen, among others:

"(...)."

FOURTEENTH: BBVA has means that allow it to verify user access to the personal data of its clients, which provide information about the date, time of access, IP address, and associated user, which allowed BBVA to know that C.C.C. was the one who accessed the information of the bank's products of A.A.A.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/28

FIFTEENTH: The data of B.B.B. is blocked under LOPD as a result of the cancellation of all products at BBVA in December 2020, and there have been no active contracts since that date.

SIXTEENTH: C.C.C. has received training from BBVA since 2018, and among other courses, the following are included:

- (...)
- (...)
- (...)
- (...)

SEVENTEENTH: According to the "Annual Report 2022," published at https://accionistaseinversores.bbva.com/wp-content/uploads/2023/03/Informe-Anual-BBVA_2022_esp.pdf, in 2022, BBVA's profit amounted to 6.420 billion euros, and it had more than 89 million customers, as stated in the diligence incorporated into the file dated February 9, 2024.

LEGAL GROUNDS

I

Competence and procedure

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary issues

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, as BBVA collects and retains, among others, the following personal data of individuals: name and surname and bank account number, among other processing activities. BBVA carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

III

Claims made

In relation to the claims made regarding the initiation agreement of this sanctioning procedure, responses are provided in the order presented by BBVA:

FIRST. – OF THE FACTS OCCURRED IN THIS CASE

BBVA summarizes the facts that occurred as follows:

- On 30/10/22, C.C.C. sent an email to various recipients, all of whom, as deduced from the surnames they have in common, are family members, in which certain banking information of A.A.A. was attached.
- According to the file, this email appears to come from C.C.C. but from an address not belonging to BBVA, as its domain is "(...)".
- C.C.C. has NOT been an employee of BBVA since 01/08/21, at which point he severed ties with the Entity due to his inclusion in the corresponding ERE.
- That is to say, at the time the aforementioned email was sent with, supposedly, the banking information of A.A.A., C.C.C. no longer had any employment relationship with BBVA.
- On March 3, 2020, C.C.C. accessed the banking data of his mother, the claimant.

From these facts, BBVA concludes the following:

- There is NO evidence that C.C.C.'s access to the accounts of A.A.A., his mother (according to BBVA), was unauthorized. Given that C.C.C. is not an employee of BBVA, his version of the events could not be heard, and therefore it has NOT been possible to establish the reason for the access to A.A.A.'s accounts. It could very well have been at his request or at the request of the various representatives that his mother, A.A.A., had designated.
- There is NO evidence that C.C.C. downloaded any banking document of A.A.A. It has only been established that he consulted A.A.A.'s accounts, but there is NO evidence of any document being downloaded by C.C.C.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/28

- It has not been proven that, in the event that any document was downloaded, that document was precisely the one that was supposedly sent TWO YEARS LATER via email.
- Similarly, there is NO evidence of the actual content of the email since what has been submitted and is recorded in the file is a forwarding of an email which can be manipulated, nor is it proven that any document was attached to that email as there is no reference to it in the body of the writing.
- There is no evidence or indication that determines that the document attached to the claim was annexed to the aforementioned email since its subject is "(...)" and the document submitted with the claim is dated 2020.
- There is NO causal link between C.C.C.'s access to the claimant's banking information (access that has not been proven to be non-consensual) and the sending of an email two years later with, supposedly, the claimant's banking information.

In this regard, this Agency wishes to point out that it has not been proven that A.A.A. was a relative of C.C.C., let alone that she is his mother. This point has been inferred by BBVA without being recorded in the file.

It is recorded, as BBVA states in its allegations, that on October 30, 2022, C.C.C. sent an email to various recipients, in which banking information of A.A.A. was attached. And that on March 3, 2020,

C.C.C., an employee of BBVA at that time, accessed financial information of A.A.A. without being authorized by A.A.A. and without it being necessary in relation to his functions.

The fact that he used an address not belonging to BBVA for this purpose is completely irrelevant for the purposes of this sanctioning procedure. Nor is the fact that when sending the email with financial information of A.A.A. he was no longer an employee of BBVA relevant, although he was at the time the information was obtained that was subsequently sent by email.

Regarding the possibility that C.C.C.'s access to A.A.A.'s financial data may have been consensual, this Agency wishes to remind that the very claim submitted by A.A.A. already indicates that he was not authorized to access such information, as A.A.A. presented a power of attorney indicating that only his three attorneys could have access to his account and none of these attorneys corresponded to C.C.C. Furthermore, it is not recorded in this procedure that the bank had any power that enabled C.C.C. to access A.A.A.'s personal data. And even in the event that it had been information requested by A.A.A. or his attorneys, this would not have allowed C.C.C. to obtain a copy of this information and use it for his own personal interests, as has occurred.

BBVA claims that there is no evidence that on March 3, 2020, C.C.C. downloaded the information about A.A.A. nor that this document was the one sent in the email of October 30, 2022, nor that the actual content of the email...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/28

except for that, since the copy submitted to the Agency can be manipulated and there is no reference to an attached document in the body of the email. It has also not been established that the document attached to the email was the one attached to the complaint, since the subject of the email is “(...)” and the supposedly attached document is dated 2020. Therefore, it considers the causal relationship between C.C.C.'s access to the claimant's banking information and the sending of the email in question, two years later, to be unproven.

In this regard, this Agency wishes to point out that it is irrelevant whether C.C.C. downloaded the information consulted about A.A.A. on March 3, 2020; it was sufficient to take a screenshot of such information, which is what is attached to the complaint.

Regarding the lack of reference to an attached document in the body of the email, this is irrelevant for the purposes of the present sanctioning procedure. This Agency considers that the financial information of A.A.A. from the year 2020 is attached to the email from 2022, whether as an attachment or as a simple image incorporated into the body of the email. And for this, it is completely irrelevant whether the subject of the email mentions the year 2022 and the information attached is from the year 2020.

In short, this Agency considers the causal link between C.C.C.'s access to A.A.A.'s banking information and the sending of the email containing such information on October 30, 2022, to be duly established.

In any case, the object of this procedure is that BBVA did not have adequate technical and organizational measures to prevent an employee of the entity from obtaining personal data of individuals whom they could not even view in relation to their functions and clients.

Therefore, this allegation is dismissed.

SECOND. - ON THE ALLEGED VIOLATION BY BBVA OF ARTICLE 32 OF THE GDPR

1. On the content of the Initiation Agreement

BBVA claims that they have security measures in place to ensure the confidentiality of the processing systems and services and that they provide information and training to their employees.

The following documents are brought up, which have been previously submitted:

- “Data Protection and Customer Experience Protocol” developed in collaboration with the Data Protection Office (DPO) and containing recommendations on how to handle customers' personal data with security and confidentiality. The protocol is available on the Entity's intranet, making it accessible to employees.

- Information to employees via a newsletter called “Hoy” provided on Monday, March 12, 2018, which includes a link to the protocol mentioned in the previous section. A screenshot is attached with the following content:

(...)

- “BBVA Group Code of Conduct” which includes the obligation of employees to safeguard and maintain the confidentiality of the data they handle. Furthermore, they are obliged not to disclose, transmit, or reveal to third parties any related information or data they have access to as a result of their activities, nor to use such information for personal gain. This obligation will persist even after the contractual relationship has ended. A screenshot is attached with the following content:

“(...)”.

A screenshot of the internal application with access to a consultation channel for any doubts that may arise regarding the application of this code is also attached, with the following content:

“(...)”.

Additionally, BBVA has established a reporting channel available to its employees to communicate behaviors that constitute a breach of the Code of Conduct. A screenshot is attached with the following content:

“(...)”.

- “Termination Letter.” Employees who participated in the ERE – as is the case with C.C.C. – formalized an agreement with the Entity that included the obligation of confidentiality and professional secrecy.

- Certificate that includes the training recorded since 2018 by former employee C.C.C., which includes, among others, the completion of the following courses:

- (...)

- (...)

- (...)

- (...)

For its part, BBVA provides new documents regarding the security measures established to ensure the confidentiality of the processing systems and services and the information and training directed to its employees:

- DOCUMENT NO. 1: “General Privacy and Data Protection Policy” established by the Board of Directors of BBVA, with the aim of safeguarding

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/28

the privacy and protection of data concerning natural and legal persons related to BBVA, and the different companies that make up the Group. A screenshot is attached regarding the principle of confidentiality integrated into this document, as one of the values of the BBVA Group:

“(...)”

-

DOCUMENT NO. 2: “Corporate Regulation on the Protection of Personal Data,” a document that refers to professional secrecy. A screenshot is attached with the following content:

“(...)”

-

DOCUMENT NO. 3: “Regulation on the Protection of Personal Data” applicable to any processing of personal data carried out, regardless of the group to which the data belongs: customers, non-customers, employees, shareholders, representatives, etc., in all units that make up the geography of Spain subject to compliance with the regulatory requirements of the country. The content of this regulation is regularly reminded to employees through information campaigns. Screenshots are attached with the following content:

“(...)”

-

DOCUMENT NO. 4: "Policy on the Protection of Personal Data Derived from Your Employment Relationship," a document that outlines the confidentiality obligation of employees. Screenshots are attached with the following content:

"(...)".

Finally, regarding the measures that BBVA has directed towards employees concerning the protection of personal data, it indicates that it has means that allow it to verify user access to the personal data of its customers. These login records, access to files, or user activity have allowed the Internal Audit Department of the Entity to obtain information about the date, time of access, IP address, and user associated with the information of the claimant's products at BBVA.

BBVA explains that the access log is a measure to ensure the adequate security of the personal data processed as it allows identifying the Group employee who consults. It is, therefore, a deterrent and preventive measure against possible unjustified access.

For the reasons stated, BBVA understands that the assertion made by the AEPD when it states that BBVA did not have sufficient technical and organizational security measures does not correspond to the reality of the facts, given that BBVA does have technical and organizational measures resulting from an adequate analysis of the risks that processing may generate on the rights of the data subjects.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/28

To this end, and as can be inferred from what has been presented so far, BBVA claims that it has established measures such as:

- Clear policies. As evidenced by the documentation in the file, as well as that provided along with these allegations, BBVA has provided guidelines to be followed by the different business areas for the implementation of security measures on the Information Systems owned by BBVA, based on the classification of the information they handle and appropriate to the assessment of the risks in data protection and security to which they are exposed.

- Restricted access. BBVA allows access to personal data of customers exclusively to those employees who need to have such data for the performance of their job functions.

- Monitoring and auditing. BBVA has measures to control employee access to customers' personal data in order to carry out adequate prevention and supervision.

- Training and awareness. BBVA regularly conducts training courses for its employees on security policies to ensure a collective awareness of the importance of conducting secure personal data processing. All of this helps to ensure adequate security in the processing of personal data.

- Reporting and communication channels. BBVA has established mechanisms for employees to confidentially report any suspicious or inappropriate activity they are aware of in order to detect and minimize risks.

BBVA claims that it has undertaken diligent activity in the implementation of the aforementioned measures, which can be deemed suitable and sufficient to ensure the adequate security of the personal data it processes; however, it cannot be required to achieve a result in the face of undesirable behaviors beyond any control. It asserts that the measures established by the Entity guarantee an adequate level of security relative to the risk, in addition to fostering an ethical work environment that promotes values of integrity and responsibility among employees.

On the other hand, it should be noted that the security measures that may result from the analysis of the risks derived from data processing must be supplemented by those arising from the application of sectoral regulations that are particularly applicable to BBVA in its capacity as a credit institution (citing

Article 83 of Law 10/2014, of June 26, on the regulation, supervision, and solvency of credit institutions, which imposes on credit institutions the duty to maintain confidentiality regarding information related to the balances, positions, transactions, and other operations of their clients, although such confidentiality has its own limits: without the same (information) being communicated to third parties or subject to disclosure).

Secondly, BBVA considers the interpretation made by the AEPD of the provisions of the GDPR to be erroneous when it states that "It is not sufficient that BBVA, as...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/28

responsible for the processing, implements security measures, but must also ensure their compliance." It is alleged that the AEPD considers that the current Data Protection regulations impose, regarding the adoption of security measures, an obligation of result, understanding BBVA that the evident spirit of the legislator, when establishing the Principle of Proactive Responsibility, is to enact an obligation of means.

In this regard, it cites the ruling of the Supreme Court of February 15, 2022 (cassation appeal 7359/2020) which clearly states that the obligation imposed by the personal data protection regulations to adopt technical and organizational measures aimed at ensuring the confidentiality, availability, and integrity of the information is an obligation of means and not of result, as the AEPD had traditionally considered and supported by the doctrine of the National Court.

As a consequence of all the above, BBVA concludes that the premises that lay the groundwork for the assessment of the circumstances of the case and that lead the AEPD to impose the infringement for the alleged violation of Article 32 of the GDPR fall before the reality of the facts, which should necessarily lead to the filing of the present file.

In this regard, this Agency wishes to point out that at no time did it understand that BBVA did not have any measures in place to ensure the confidentiality of its clients' personal data. Nor did it indicate in its initiation agreement that the obligation of Article 32 of the GDPR was an obligation of result.

The initiation agreement of the present sanctioning procedure itself acknowledged that BBVA had measures in place, but that these were not "sufficient to prevent a security breach of the personal data of clients, data of which the bank is the owner." And that: "While it is true that BBVA had some measures aimed at employees regarding the protection of personal data, such as providing information and training; it is evident that they are insufficient to prevent an incident similar to the issue that gave rise to the present procedure. Furthermore, it is not enough for BBVA, as the data controller, to implement security measures; it must also ensure their compliance."

BBVA indicates in its allegations a series of measures that it has implemented to prevent the violation of its clients' personal data by its employees. Primarily, these involve providing information to its employees about their confidentiality obligations and what they are not authorized to do. It also includes providing information through training on the subject.

In this regard, the documents provided by BBVA either do not indicate the date they were adopted or bear a date subsequent to the access of A.A.A.'s personal data by C.C.C. in 2020, when he was still an employee of BBVA:

- Data Protection Protocol "Data Protection Office (DPO)": no date indicated
- "BBVA Group Code of Conduct": no date indicated

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/28

- "General Privacy and Data Protection Policy": dated September 28, 2022
- "Corporate Regulation on Personal Data Protection": dated May 19, 2023
- "Regulation on the Protection of Personal Data": dated April 1, 2022

Before the year 2020, it is only indicated that C.C.C. has received training from BBVA since 2018 and that on March 12, 2018, information was provided to BBVA employees through a newsletter called "Hoy" with a link to the document "Data Protection Protocol," but there is no information on whether such newsletter was mandatory reading for those employees or if those employees accessed its content and the aforementioned protocol.

In all the documentation provided by BBVA in its responses to the transfers of the complaints and responses to information requests from this Agency and in its statement of allegations, there is no information regarding measures to ensure that such obligations are fulfilled by its employees. The only measure in this regard would be the aforementioned control of login records, access to files, or user activity, which allows verification of user access to customers' personal data and which has enabled the Internal Audit Department of BBVA to know that on March 3, 2020 (date of the account statement), a query of movements of the IBAN account ES000000000000000000000000 was made from the office (...) located at ***ADDRESS.1, which does not correspond to the managing office of the account. And that the user recorded in the transaction log, and who therefore accessed the balance and movements of the account, was C.C.C., an employee of BBVA from 03/16/1992 to 08/01/2021, the effective date of voluntary resignation incentivized due to his inclusion in the ERE (Employment Regulation File).

However, this information was only useful once the complaints subject to this procedure were known; it was not used beforehand, nor is there any evidence in the file that there were procedures to control that everything detailed in the documents provided to employees was complied with, nor that there were controls for this that were carried out by the entity regularly.

Although the bank had measures to achieve traceability of who accessed the personal data of its clients, it is not recorded in this procedure that audits or subsequent reviews were conducted due to, for example, a complaint, nor that appropriate technical and organizational measures were implemented so that each employee could only access the personal data of those clients assigned to them at a given time and prevent any employee from accessing the personal data of any client.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

20/28

There are no preventive measures in this case. The risk-based approach of the GDPR and its preventive nature are not addressed.

By virtue of Article 5.2 of the GDPR, BBVA is obliged: "The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it ('proactive accountability')."

In none of its submitted writings, nor in the writings of March 17, 2023, responding to the transfers of the complaints, nor in the writings of June 21, 2023, or August 21, 2023, responding to requests from this Agency, nor in its statement of allegations of March 8, 2024, has information been provided that measures were adopted to ensure compliance with everything included in the aforementioned documentation. This cannot be understood by this Agency as an obligation (of means) duly fulfilled by BBVA.

For all the above reasons, this allegation is dismissed.

2. On the absence of a causal link between the access to the data by C.C.C.

BBVA insists that "neither from the factual account of the complaint nor from the documentation in the file or from the evidence presented by the AEPD, it can be inferred that C.C.C. downloaded any information from the complainant and that this same information was the one that, two years later, was apparently sent without the complainant's consent to various recipients."

BBVA insists that the file shows that C.C.C., in the exercise of his functions as an employee of BBVA – it is unknown, as third parties have not been asked, if even under the mandate of the complainant or

any of the authorized persons in their products – accessed the complainant's account on March 3, 2020.

And it has not been proven:

- (i) that such access was not consented to or known by the complainant
- (ii) that C.C.C. downloaded any type of documents during that access
- (iii) that the alleged documents downloaded in 2020 were, moreover, the ones sent by email (external to the Entity, both the email address and C.C.C., who was no longer an employee of BBVA) to various recipients
- (iv) that the documents included in the complaint were the ones attached to the aforementioned email given that it refers to "donation mama November 2022" and the document attached is from the year 2020.

BBVA argues that without having heard C.C.C. and without any evidence that in March 2020 he downloaded any type of information from the complainant, the AEPD, with its ruling, is violating the principle of presumption of innocence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/28

applicable principle to sanctioning administrative law (citing Supreme Court rulings of September 29, November 4 and 10, 1980, and STC 18/1981).

And that the principle of culpability or subjective responsibility is also applicable, as it is considered essential for the existence of the administrative offense (citing STC 76/1990 of April 26, rulings of February 22, 1992, and June 5, 1989, and STS of July 9, 1994).

BBVA insists that it has NOT been proven that C.C.C. is guilty of the improper downloading of the data sent via email, given that there is no evidence of the download of such information on March 3, 2020, and it could be – if they were – the extracts sent by email, two years later, documents obtained outside the scope of his employment relationship (which was terminated in 2021) with BBVA (they could be documents obtained at his mother's home, provided by a relative, etc.).

BBVA argues that in the case at hand, the infringement has not even been proven (as there is no evidence of the documents being downloaded by C.C.C. nor any evidence that the access to the claimant's data was not consented to by her), and therefore, the presence of intent or negligence regarding the same cannot be proven.

BBVA insists that when a person decides to forward an email, it can be subject to modifications at the discretion of the person forwarding it, so there is no record that the email sent by C.C.C. on November 15, 2022, contained either the text that the claimant states or that any document was attached to it, since, as demonstrated below, when an email containing an attachment is sent, a symbol appears at the top right (in the shape of a "clip") that indicates the sending of an attachment. A screenshot of an email is attached, highlighting in yellow the image of a clip in the upper right corner.

BBVA argues that in the case at hand, from the forwarded email, it does not appear that there was an attachment. A screenshot of the email sent by C.C.C. is copied, in which such a clip does not appear in the upper right.

BBVA insists that the email has the subject "(...)" and the document that is supposedly attached is dated 2020, which again undermines any indication of C.C.C.'s culpability regarding the matter and, consequently, BBVA's responsibility.

Therefore, BBVA insists, there is no evidence whatsoever:

- (i) of the sending of the documentation provided with the complaint, as neither the subject of the email nor the documentation provided by the claimant has any connection to C.C.C.
- (ii) nor that such documentation, if it had indeed been sent, was downloaded by C.C.C. in the exercise of his functions at BBVA.

C/ Jorge Juan, 6

www.aepd.es

22/28

Given that these allegations are the same as those previously addressed, this Agency reiterates what has already been stated in the responses to such allegations and in the facts considered proven in this resolution.

Therefore, the present allegation is dismissed.

3. Regarding the complaint concerning the data of

B.B.B..

BBVA indicates that it presents allegations regarding the complaint filed by B.B.B., despite the fact that it is filed under a different case number than the one at hand, given the continuous reference to it made in this procedure.

In this regard, this Agency wishes to point out that the present sanctioning procedure originates from two complaints: the one filed by A.A.A. on November 15, 2022, and the one filed by B.B.B. on November 17, 2022, which have been consolidated in the present sanctioning procedure, as already reflected in the initiation agreement of this procedure.

Regarding the complaint filed by B.B.B., BBVA alleges:

- Regarding C.C.C.'s access to B.B.B.'s data. As was evidenced at the request of the AEPD, during the period from 01/01/2022 to 30/10/2022, there are no accesses to computer applications of B.B.B.'s data. Therefore, there is NO evidence of access to B.B.B.'s data by C.C.C.
- Regarding the documents that supposedly appear in the email sent by C.C.C. in 2022:
 - (i) the first three images seem to correspond to the mechanical validation of account deposits; if so, the person making the deposit receives a copy of the deposit receipt, so again, access to such documentation by C.C.C. is not evidenced.
 - (ii) the third image is illegible; it appears to be a screenshot of BBVA's application.
 - (iv) the fifth, sixth, and seventh images seem to correspond to an amortization table of a loan (installments from 2003 to 2013); there is no causal link between these images and the alleged unauthorized data transfer by BBVA.
 - It is not evidenced that access to the documentation apparently from the years 2008 and 2013 was provided by BBVA to a third party other than the holder. Any document that corresponds, for example, as in this case, to an amortization table of a loan, in the hands of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/28

Access by a third party different from the holder does not imply a violation of the client's data protection by the Entity, as access to the document once it is delivered to the client during the formalization of the operation is beyond the control of the Bank.

In this regard, this Agency wishes to point out that the fact that the data was not consulted during that period in 2022 does not mean that C.C.C. could not have obtained it earlier. What is evidenced in the file is that C.C.C., a former employee of BBVA, had obtained such information while he was still an employee of the bank and used it for his own interests.

This Agency considers that there is indeed a sufficient causal link between C.C.C.'s access to the information, as he was an employee of BBVA, and its use for his own interests, having shared it with third parties via an email dated November 15, 2022.

Finally, BBVA reiterates the allegations made regarding the forwarding of an email, the vulnerability of its content once it is forwarded, and the lack of evidence that there were attachments in that email, therefore this Agency reiterates its response to such allegations provided previously.

For all the above, the present allegation is dismissed.

IV

Security of Processing

Article 32 "Security of Processing" of the GDPR states:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying risks of probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless he or she is required to do so by Union or Member State law."

In the present case, BBVA did not have sufficient technical and organizational security measures to prevent a security breach of the personal data of clients, data for which the bank is the holder.

Although the bank had measures to achieve traceability of who had accessed the personal data of its clients, it is not recorded in the present procedure that audits or subsequent reviews were carried out, for example, following a complaint, nor that appropriate technical and organizational measures had been implemented so that each employee could only access the personal data of those clients assigned to them at a given time and prevent any employee from accessing the personal data of any client.

There are no prior preventive measures in the present case. The risk-based approach of the GDPR and its preventive nature are not addressed.

While it is true that BBVA had some measures directed at employees regarding the protection of personal data, such as providing information and training; it is evident that these are insufficient to prevent an incident similar to the issue that gave rise to the present procedure. Furthermore, it is not enough for BBVA, as the data controller, to implement security measures; it must also ensure their compliance.

Therefore, in accordance with the evidence available at this moment of the sanctioning procedure resolution, it is considered that the known facts constitute an infringement attributable to BBVA for violation of the previously transcribed article.

V

Classification and Qualification of the Infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of one of the infringements classified in Article 83.4 of the GDPR, which under the heading "General Conditions for the Imposition of Administrative Fines" states:

"4. Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total worldwide annual turnover of the preceding financial year, whichever is higher."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the data controller and the data processor pursuant to Articles 8, 11, 25 to 39, 42, and 43; (...)"

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a two-year limitation period, in accordance with Article 73 of the LOPDGDD, which qualifies the following conduct as serious:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and will be subject to a two-year limitation period, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679. (...)"

VI

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at the present time of the resolution of the sanctioning procedure, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected individuals and the level of damage and harm suffered (paragraph a): for not having the appropriate security measures in place to mitigate the risk of a personal data breach such as that which has occurred in this case, which allowed for the improper processing of several documents containing data from two affected individuals.
- Any previous infringement committed by the data controller or the data processor (paragraph e): this Agency has two sanctioning procedures (PS/00419/2022 and PS/00429/2022) in which resolution decisions were adopted on 28/09/2022 and 11/11/2022. In both cases, BBVA was charged with the infringement of Article 32 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

It is also considered appropriate to graduate the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): BBVA, a financial entity, and the large number of clients it has, involves handling a significant amount of personal data. Not having the appropriate technical and organizational measures in place to prevent bank employees from accessing clients' personal data without authorization or necessity for their functions poses a risk to the privacy of all BBVA clients' data.

The balance of the circumstances considered in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of an administrative fine of 70,000 euros.

VII

Imposition of measures

In accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing

operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”, BBVA is required to demonstrate to this Agency within six months the adoption of the necessary measures to ensure compliance with the provisions of Article 32 of the GDPR, in order to prevent a similar incident to that which gave rise to this procedure.

The imposition of these measures is compatible with imposing an administrative fine, as provided for in Article 83.2 of the GDPR.

It is noted that failure to comply with the possible order to adopt measures imposed by this agency in the resolution that concludes this procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, which may lead to the initiation of a further sanctioning administrative procedure.

VIII

Termination of the procedure

Article 85 of the LPACAP, under the heading “Termination in sanctioning procedures” provides the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/28

“1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the latter has been justified as inappropriate, voluntary payment by the alleged responsible party at any time prior to the resolution will imply the termination of the procedure, except in relation to the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which may be cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation.”

In accordance with the above,

the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202300329, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO ORDER BANCO BILBAO VIZCAYA ARGENTARIA, S.A., with NIF A48265169, that pursuant to Article 58.2.d) of the GDPR, within six months from the date this resolution becomes final and enforceable, to demonstrate to this Agency the adoption of the necessary measures to ensure compliance with the provisions of Article 32 of the GDPR, in order to prevent a similar incident to that which gave rise to this procedure.

THIRD: TO NOTIFY this resolution to BANCO BILBAO VIZCAYA ARGENTARIA, S.A.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es

28/28

1398-101224

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es